**Ad Soyad / Grup:** Talha Yılmaz / Gece-B 235541107 **Tarih:** 25-10-2026

**Uyarlanan Makine:** ALES UTEC400E Seal Jet (Contour-Cut CNC Sızdırmazlık Conta Üretim Sistemi - Körleme Testi)

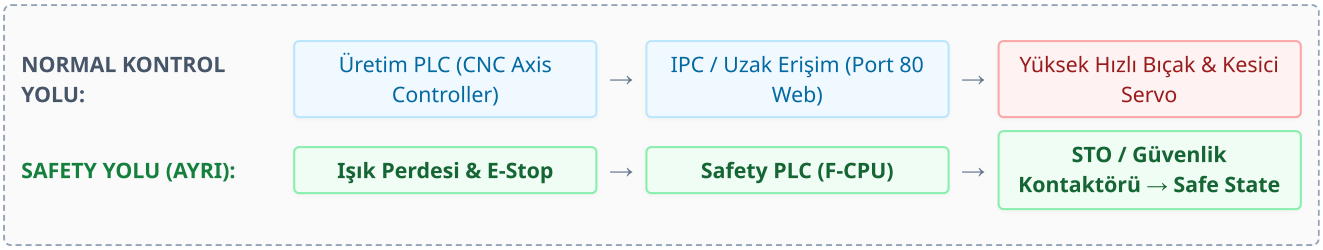
LABORATUVAR 1 — GENEL SÜRÜM

# Safety Architecture & Dijital Bağımlılıklar

**Çıktı: Safety Function Map**

**Kavram:** Emniyet fonksiyonu, insanı koruyan fonksiyondur ve ayrı bir safety yolunda yaşar (E-stop → Safety PLC → STO). Gerekli güvenilirliği (PLr/SIL) riskle orantılıdır ve bu güvenilirlik, dijital bir konfigürasyona bağlıdır.

## MİMARİ Mimari Yapı Şeması (ALES UTEC400E Uyarlaması)




## GÖREV Soruları UTEC400E Bağlamında Cevaplayın

**1. Bu makinede tehlike nedir? İnsan neyden zarar görür?**

ALES UTEC400E Seal Jet'te yüksek hızlı dönen kesme bıçağı, talaş alma mili ve hidrolik conta sıkıştırma eksenleri mevcuttur. İnsan, bıçak kesmesi, uzuv kopması ve yüksek basınçlı hidrolik sıkışmasından zarar görür.

**2. Safety function (emniyet fonksiyonu) hangisidir?**

E-Stop'a basılması veya ışık perdesi ihlalinde: "Kesme mili servolarına STO (Safe Torque Off) uygulamak ve hidrolik ana besleme valfini derhal kapatarak kesici başlığı güvenli duruşa geçirmek."

**3. Normal PLC ile Safety PLC farkı nedir? Neden PLr/SIL gereklidir?**

Normal PLC üretimi ve CNC kodlarını yürütür; donanımsal/yazılımsal hata toleransı yoktur. Safety PLC ise çift kanallı (redundant), çapraz denetimli ve donanım arızasında sistemi güvenli duruma geçirecek yapıdadır. PLr, emniyetin siber veya elektriksel arızada mantıksal çökmemesini garantiler.

**4. Safety function hangi dijital bağımlılıklara sahip ve siber müdahale bunu nereden bozar?**

Safety PLC donanım yazılımı (firmware), PROFIsafe veri yolu parametreleri ve güvenlik sınır değerlerine bağımlıdır. Siber müdahale, mühendislik portundan veya OT ağına sızarak Safety PLC projesindeki checksum/parametreyi değiştirip koruma mantığını devre dışı bırakabilir.

☑ **Bu föyün çıktısı Safety Function Map → Evidence Pack EP 03 Safety Functions başlığına oturur.**

**Ad Soyad / Grup:** Talha Yılmaz / Gece-B 235541107 **Tarih:** 25-10-2026

**Uyarlanan Makine:** ALES UTEC400E Seal Jet (Contour-Cut CNC Sızdırmazlık Conta Üretim Sistemi - Körleme Testi)

LABORATUVAR 2 — GENEL SÜRÜM

# IEC 62443 Mini Workshop

**Çıktı: Zone / Conduit Diagram**

> **Kavram:** Zone = Benzer kritiklikteki cihazları bir bölgeye topla. Conduit = Bölgeler arası her geçişe kontrollü bir kapı. IEC 62443'ün maddesini ezberlemiyoruz, mantığını UTEC400E'ye uyguluyoruz.

## GÖREV A Varlıkları Bölgelere (Zones) Ayırın

**1. Varlık Grupları ve Bölge Adlandırmaları (UTEC400E Varlıkları)**

- **Safety Zone (Bölge 1 - Kritik):** Safety PLC, E-stop, Işık perdesi, STO Devresi.
- **Control Zone (Bölge 2 - Operasyon):** UTEC CNC Kontrolörü, Motor Sürücüler, HMI İstemcisi.
- **Enterprise/DMZ Zone (Bölge 3 - Dış Erişim):** Mühendislik İstasyonu, Uzak Servis Gateway, Kurumsal ERP.

**2. Safety PLC'yi hangi bölgeye koydunuz — neden?**

Safety PLC en yüksek güvenlik seviyesindeki **Safety Zone (Bölge 1)** içerisine konulmiştir. Nedeni: Üretim PLC'sindeki veya ağdaki siber saldırılardan fiziksel emniyet mekanizmasının doğrudan etkilenmesini önlemek ve siber erişimi sıfırlamaktır.

**3. Bölgeler arası geçişler (Conduit) nerede? Ne kontrol edilecek?**

Conduit 1 (Control → Safety): Sadece okunabilir PROFIsafe durumu. Conduit 2 (DMZ → Control): Endüstriyel Firewall üzerinden sadece IPsec VPN, 802.1x kimlik doğrulama ve deep packet inspection (DPI) ile CNC G-kodu aktarımı.

## GÖREV B Uzak Erişim Karar Tablosu (6 Satır)

| Karar | Seçenekler | Seçiminiz + Nedeni (UTEC400E Uyumlu) |
|---|---|---|
| **Aracı?** | Doğrudan / Jump server | **Jump Server (Bastion Host):** Doğrudan CNC PLC'ye bağlantıyı engeller. |
| **Tünel?** | Açık / VPN | **IPsec VPN + TLS 1.3:** Şifrelenmiş tünel üzerinden güvenli iletim. |
| **Kimlik?** | Parola / MFA | **MFA (Çok Faktörlü):** Statik parola sızıntılarına karşı zorunlu 2FA. |
| **Hesap?** | Paylaşılan / Kişisel | **Kişisel (Named User):** Sorumluluk takibi ve izlenebilirlik için. |
| **Kayıt?** | Yok / Tam oturum kaydı | **Tam Oturum Kaydı:** RDP/SSH tüm tuş vuruşları ve komutlar kaydedilir. |
| **Zamanlama?** | Sürekli açık / Varsayılan kapalı | **Varsayılan Kapalı (On-Demand):** Bakım zamanı fiziksel anahtarla açılır. |

☑ **Bu föyün çıktısı Zone / Conduit Diagram → Evidence Pack EP 05 Zone & Conduit başlığına oturur.**

**Ad Soyad / Grup:** Talha Yılmaz / Gece-B 235541107 **Tarih:** 25-10-2026
**Uyarlanan Makine:** ALES UTEC400E Seal Jet (Contour-Cut CNC Sızdırmazlık Conta Üretim Sistemi - Körleme Testi)

LABORATUVAR 3 — GENEL SÜRÜM
## Threat & Risk + Risk Matrix

**Çıktı: Risk Register**

**Kavram:** Senaryo beş parçadır: Kim → Hangi kapı → Ne yapar → Zincir → FİZİKSEL sonuç. Skor = L x S x E (her biri 1-3). Kural: S=3 ise skor düşük olsa bile senaryo öne alınır — insana zarar görünür kalır.

### GÖREV Üç Senaryo Kurun ve Puanlayın (ALES UTEC400E Senaryoları)

| Senaryo (Kim → Kapı → Ne yapar → Zincir → Fiziksel Sonuç) | L | S | E | Skor | Öncelik |
|---|---|---|---|---|---|
| **1. Dış Saldırgan** → Açık Port 80 HMI → CNC G-Kod Değişimi → Kesici kafayı maksimum hızda hammaddeye çarptırır → *Bıçak kırılması, parça fırlaması, operatör yaralanması.* | 3 | 3 | 2 | **18** | **Kritik (18-27)** |
| **2. Kötü Niyetli Personel** → Kilitsiz USB → Safety PLC Override → Işık perdesi bypass → *Operatör müdahalesinde kesici mil durmaz, el/kol kopması.* | 1 | 3 | 3 | **9** | **Yüksek (9-17)** |
| **3. Yetkisiz Servis** → Zayıf VPN Parolası → PLC Firmware Manipülasyonu → Hidrolik basınç sensörü değerini yanıltma → *Conta sıkıştırma ünitesi patlaması, hidrolik yağ yanması.* | 2 | 2 | 2 | **8** | **Orta (4-8)** |

**1. En yüksek öncelikli senaryonuz hangisi? Bir cümleyle: Neden bu?**

1. Senaryodur (Skor 18). Çünkü internete açık HMI portu üzerinden CNC G-koduna yetkisiz müdahale yapılması en kolay sızma yoludur ve yüksek devirli bıçağın kırılıp operatörün yaralanmasıyla doğrudan sonuçlanır.

**2. S=3 olup skoru düşük kalan senaryonuz var mı? Nasıl görünür kılacaksınız?**

Evet, 2. Senaryo (USB ile Işık Perdesi Bypass) olasılığı düşük (L=1) olduğu için skoru 9 çıkmıştır. Ancak insan hayatına doğrudan tehdit (S=3) oluşturduğu için "Altın Kural" gereği öncelikler listesinin en üstüne (Kritik Takip) çekilmiştir.

**Altın Kural:** Zincir "veri çalındı" ile bitiyorsa emniyet bulgusu değildir; bir adım daha gidin: Bu, UTEC400E hattındaki operatöre ne yapar?

☑ **Bu föyün çıktısı Risk Register → Evidence Pack EP 04 Risk Assessment başlığına oturur.**

**Ad Soyad / Grup:** Talha Yılmaz / Gece-B 235541107 **Tarih:** 25-10-2026
**Uyarlanan Makine:** ALES UTEC400E Seal Jet (Contour-Cut CNC Sızdırmazlık Conta Üretim Sistemi - Körleme Testi)

LABORATUVAR 4 — GENEL SÜRÜM
## Secure Remote Access

**Çıktı: Secure Architecture**

> **Kavram:** İki katman, ikisi de şart: Erişim güvenliği (girişi zorlaştır: ara nokta, VPN, MFA, kişisel hesap, kayıt, varsayılan kapalı) + Emniyet bağımsızlığı (girse bile insan korunur).

### GÖREV A Mevcut ve Hedef Mimari Karşılaştırması

**MEVCUT DURUM (Güvenlik Açıklı Yapı):**

> ALES UTEC400E üzerindeki modem/gateway doğrudan internete bağlı. Servis firması port forwarding ile şifresiz VNC/RDP üzerinden CNC kontrolörüne ve HMI'a erişiyor. Ortak "admin/1234" hesabı kullanılıyor, oturum kaydı tutulmuyor.

**HEDEF DURUM (Beş İlkeyle Yeniden Tasarlanmış Güvenli Mimari):**

1. **Erişim Kapısı:** İzole DMZ bölgesinde Jump Server.
2. **Kimlik & Tünel:** MFA doğrulama ile IPsec VPN tüneli.
3. **Hesap Yönetimi:** Named User (Mühendis bazlı kişisel hesaplar).
4. **Denetim:** SSH/RDP oturumlarının video ve log kaydı.
5. **Fiziksel Anahtar:** Makine üzerindeki anahtarla varsayılan KAPALI uzaktan erişim kapısı.

### GÖREV B Functional Safety Köprüsü

**1. Saldırgan tüm önlemlere rağmen içeri girerse: Emniyet fonksiyonu etkilenir mi? Neden?**

> Etkilenmemelidir. Emniyet fonksiyonu (Safety PLC ve STO devresi), üretim ağından ve uzaktan erişim kanallarından donanımsal ve mantıksal olarak bağımsız tasarlanmıştır. Uzak erişim sadece CNC üretimi etkiler, emniyet duruşunu engelleyemez.

**2. Emniyet fonksiyonunun kontrol sisteminden bağımsız çalışması için GEREKSİNİMİ yazın (çözümü değil):**

> **Gereksinim:** "Herhangi bir ağ arayüzünden, üretim PLC'sinden veya uzak oturumdan gelen hiçbir komut veya parametre değişikliği, donanımsal E-Stop ve Işık Perdesi kesme mantığını geçersiz kılamaz (override edemez)."

> *Tarafsızlık notu: Bu föy çözüm tasarlatmaz; gereksinimi tanımlatır. Tasarım kararı firmanızındır.*

☑ **Bu föyün çıktısı Secure Architecture → Evidence Pack EP 02 + EP 06 başlığına oturur.**

**Ad Soyad / Grup:** Talha Yılmaz / Gece-B (235541107) **Tarih:** 26-10-2026
**Uyarlanan Makine:** ALES UTEC400E Seal Jet (Contour-Cut CNC Sızdırmazlık Conta Üretim Sistemi - Körleme Testi)

LABORATUVAR 5 — GENEL SÜRÜM
# SBOM / CVE / Patch Decision

**Çıktı: Vulnerability Decision**

**Kavram:** SBOM = Yazılım Malzeme Listesi, CVE = Açığın Kayıt No'su, CVSS = Ciddiyet (0-10). Bir CVE sizi etkiler mi? Üç şart: Bileşen var, sürüm etkileniyor, açık ulaşılabilir.

## GİRDİ Verilen Zafiyet Kaydı (UTEC400E Bileşeni)

| | |
|---|---|
| **Bileşen** | Component X (UTEC CNC Controller Firmware Kütüphanesi) |
| **Sürüm** | v2.4 (Mevcut Makine Sürümü) |
| **CVE No** | CVE-2026-8842 (Uzaktan Kod Çalıştırma / Buffer Overflow) |
| **Önem (CVSS)** | **Critical (CVSS 9.8)** |
| **Yama Durumu** | Mevcut (v2.5 Yama Paketi Yayınlandı) |

## GÖREV Karar Akışını Doldurun

**1. Bu CVE sizi gerçekten etkiliyor mu? (Üç şartı kontrol edin)**

**Evet etkiliyor.** 1. Bileşen var (UTEC CNC Kontrolörü). 2. Sürüm etkileniyor (v2.4 yüklü). 3. Açık ulaşılabilir (CNC kontrolörünün Ethernet portu iç ağa bağlı).

**2. Üretimi hemen durdurur musunuz? Neden / neden değil?**

**Hayırdır, üretim hemen durdurulmaz.** Fiziksel emniyet (Safety PLC) bağımsız olduğu için doğrudan can güvenliği riski yoktur. Yama planlı bakım duruşuna kadar ertelenir.

**3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?**

Doğrudan sahada uygulanmaz. Önce fabrika dışı Test Rig / FAT Simülasyon ortamında yüklenip CNC eksen hareketleri ve haberleşme doğrulanır.

**4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?**

Firmware sürüm değişim raporu incelenir. Emniyet checksum (F-Signature) değişmişse safety re-validation (ISO 13849-2 testi) zorunludur; değişmemişse gerek yoktur.

**5. Yama mümkün değilse compensating control (telafi edici önlem) ne olur?**

CNC portu üzerindeki IP trafiği kısıtlanır, firewall üzerinden sadece statik Mühendislik IP'sine izin verilir ve uzaktan erişim fiziksel olarak kilitlenir.

☑ **Bu föyün çıktısı Vulnerability Decision → Evidence Pack EP 09-10-11 başlığına oturur.**

**Ad Soyad / Grup:** Talha Yılmaz / Gece-B 235541107 **Tarih:** 03-11-2026
**Uyarlanan Makine:** ALES UTEC400E Seal Jet (Contour-Cut CNC Sızdırmazlık Conta Üretim Sistemi - Körleme Testi)

LABORATUVAR 6 — GENEL SÜRÜM

## CRA Incident Simulation (Olay Müdahale Simülasyonu)

Çıktı: Incident Workflow

**Senaryo & Kavram:** Saat 10:15. Servis hesabında yetkisiz erişim tespit edildi. UTEC400E CNC konfigürasyonu değişmiş olabilir. Makine hâlâ çalışıyor. Vardiya sorumlusu sizsiniz. CRA (Cyber Resilience Act) yükümlülükleri (24s / 72s / 14 gün) rehber alınır.

### GÖREV Zaman Çizgisini Doldurun (Olay Müdahale Adımları)

**1. 10:15 İlk 15 dk: Kimi ararsınız? İlk üç eyleminiz?**

• **Aranacaklar:** OT Güvenlik Sorumlusu ve Emniyet/İSG Uzmanı.
• **İlk 3 Eylem:** 1. Ağ kablosunu/VPN bağlantısını fiziksel olarak sök (İzole et). 2. Makineyi güvenli moda (Safe Stop) al. 3. CNC Kontrolörü kapatma veya resetleme yapma (Volatile RAM loglarını koru!).

**2. İlk 2 saat: Emniyet güvende mi? Neyi korursunuz (Kanıt!)? Hangi hesap kapatılır?**

Safety PLC checksum doğrulanarak E-Stop/Işık Perdesi mekanik donanımı manuel test edilir. Ağ trafiği pcap dökümleri ve PLC erişim logları adli kanıt olarak alınır. Yetkisiz giren Servis/Mühendislik hesabı derhal dondurulur.

**3. 24 Saat — CRA Erken Uyarı (Early Warning Notification):**

Yetkili otoritelere (ENISA / Ulusal CSIRT) olay bildirimi yapılır. Hazır bulunması gereken bilgi: İhlal zamanı, etkilenen UTEC400E makine ID'si, potansiyel siber risk düzeyi ve alınan ilk izolasyon önlemleri.

**4. 72 Saat — CRA Bildirimi (Incident Notification):**

Kök neden analizi (saldırgan zayıf VPN şifresiyle sızdı), olayın güvenlik fonksiyonlarına etkisi, uygulanan yama/düzeltme adımları ve tekrarını önleyici teknik tedbirler resmi makamlara sunulur.

**5. 14 Gün — Son Rapor (Final Incident Report):**

Korunması gereken kayıtlar: Güvenlik Duvarı pcap dosyaları, PLC audit logları, adli kopyalar (forensic images). Rapor içeriği: Sızma haritası, çıkarılan dersler ve SBOM/Firmware güncelleme kayıtları.

**En Sık Hata:** "Resetleyip devam edelim" o düğme, kanıtı sonsuza dek siler! Önce emniyet, hemen sonra kanıt koruma.

☑ **Bu föyün çıktısı Incident Workflow → Evidence Pack EP 13 Incident Response başlığına oturur.**

**Ad Soyad / Grup:** Talha Yılmaz / Gece-B 235541107 **Tarih:** 08-11-2026
**Uyarlanan Makine:** ALES UTEC400E Seal Jet (Contour-Cut CNC Sızdırmazlık Conta Üretim Sistemi - Körleme Testi)

LABORATUVAR 7 — GENEL SÜRÜM
## AI Safety Challenge

Çıktı: AI Fail-Safe Decision

**Kavram (Prediction Safety):** Yapay zekâ bir karar üretir; güvenliği garanti eden mimari YZ'nin dışında tanımlanmalıdır. Araçlar: fail-safe, human override, monitoring, confidence threshold, fallback.

**SENARYO** **Kamera → YZ Modeli (Körleme Conta Kalite Kontrolü) → OK/RED → CNC Parametresi**

**GÖREV** **Üç Başarısızlık Durumunda Güvenli Davranış Karar Tablosu**

| Başarısızlık Durumu | Tanımladığınız Güvenli Davranış (Kavramlarla Açıklayın) |
|---|---|
| **1. Model Yanlış Sınıflandırdı** (Kusurlu körleme contasına OK verdi) | **Mekanik İkinci Kontrol + Human Override:** YZ çıktısı doğrudan CNC milini başlatmaz. Lazer profil ölçer ile fiziksel çap doğrulama yapılır. Uyuşmazlıkta parça RED kutusuna atılır ve operatör onayına düşürülür. |
| **2. Girdi Manipüle Edildi** (Kamera verisi bozuk / sahte / bulanık) | **Input Monitoring & Fail-Safe Stoppage:** Kamera görüntü akışında gürültü/parazit tespit edildiğinde YZ çıkarımı durdurulur. Sistem varsayılan olarak "RED/Kusurlu" kabul eder (Fail-Safe) ve kamera temizleme uyarısı verir. |
| **3. Confidence Düşsel Değeri Düştü** (YZ Modeli %60 emin değilim diyor) | **Confidence Threshold & Fallback:** Güven eşiği **%92** olarak set edilmiştir. %92 altındaki skorlarda YZ yetkisi devreden çıkar; sistem deterministik mekanik ölçüm moduna (Fallback) geçer. |

**Mimari İlke Kararı (AI Safety Architecture):**

> YZ modeli hiçbir zaman doğrudan Safety PLC veya STO hattını tetikleyecek emniyet karar mekanizmasına bağlanamaz. YZ sadece kalite sınıflandırması yapar; emniyet tamamen bağımsız deterministik donanım tarafından sağlanır.

☑ **Bu föyün çıktısı AI Fail-Safe Decision → Evidence Pack EP 03 + EP 15 başlığına oturur.**